

Integrasi Keamanan Informasi pada Sistem Pengembangan Lost and Found IPB University

Integration of Information Security in the IPB University Lost and Found System

RAHMA DHANA*, NISA AMELIA¹, KASYIFA NAILA¹

Departemen Ilmu Komputer, Fakultas Matematika dan Ilmu Pengetahuan Alam, Institut Pertanian Bogor, Bogor 16680

Abstrak

Sistem *Lost and Found* berbasis web di lingkungan kampus menyimpan data-data sensitif pengguna sehingga rentan terhadap ancaman siber seperti *session hijacking* dan pencurian data melalui *SQL Injection*. Penelitian ini bertujuan mengimplementasikan *framework Authentication, Authorization, dan Accounting (AAA)* pada Sistem *Lost and Found IPB University* serta mengevaluasi dampaknya terhadap keamanan dan performa sistem. Metode yang digunakan meliputi *threat modeling* berbasis STRIDE untuk identifikasi ancaman, perancangan arsitektur keamanan berlapis yang mencakup autentikasi berbasis *bcrypt* dan *session management*, otorisasi berbasis peran (RBAC), enkripsi data menggunakan AES-GCM, pencegahan *SQL Injection* dengan *Prepared Statement*, serta pencatatan *audit trail* seluruh aktivitas pengguna. Pengujian keamanan menunjukkan bahwa seluruh skenario ancaman yang diidentifikasi berhasil dimitigasi: login tidak valid ditolak, akses lintas peran dicegah, dan seluruh aktivitas kritis tercatat dalam log. Pengukuran kinerja menunjukkan adanya *overhead* performa rata-rata sebesar 20,8% akibat penambahan lapisan keamanan, namun masih dalam batas yang dapat diterima untuk aplikasi web. Implementasi *framework AAA* terbukti meningkatkan keamanan sistem secara signifikan tanpa mengurangi kenyamanan pengguna secara berarti.

Kata kunci: *akuntansi, autentikasi, otorisasi, keamanan informasi, lost and found, sistem web*

Abstract

A web-based *Lost and Found* system in a campus environment stores sensitive user datas, making it vulnerable to cyber threats such as *session hijacking* and *SQL Injection-based data theft*. This study aims to implement the *Authentication, Authorization, and Accounting (AAA)* framework in the *IPB University Lost and Found System* and evaluate its impact on security and system performance. The methods used include *STRIDE-based threat modeling* for threat identification, layered security architecture design encompassing *bcrypt-based authentication and session management*, role-based access control (RBAC), *AES-GCM data encryption*, *SQL Injection prevention via Prepared Statements*, and comprehensive *audit trail logging of all user activities*. Security testing demonstrated that all identified threat scenarios were successfully mitigated: invalid logins were rejected, cross-role access was prevented, and all critical activities were recorded in the log. Performance measurements showed an average performance overhead of 20.8% due to added security layers, which remains within acceptable limits for web applications. The implementation of the *AAA framework* significantly improves system security without meaningfully reducing user convenience.

Keywords: *accounting, authentication, authorization, information security, lost and found, web system*

¹Program Studi Ilmu Komputer, Sekolah Sains Data, Matematika, dan Informatika, Institut Pertanian Bogor, Bogor 16680;

*Penulis Korespondensi: Tel/Faks: +6285709040274, Surel: dhnadhana@apps.ipb.ac.id

PENDAHULUAN

Pengelolaan barang hilang di lingkungan kampus perguruan tinggi merupakan layanan penting yang mendukung kesejahteraan civitas akademika. Di *IPB University*, proses pelaporan dan pengelolaan barang hilang masih banyak dilakukan melalui saluran informal seperti *group WhatsApp* dan unggahan *story* pada *platform Instagram*. Metode informal ini menimbulkan berbagai permasalahan struktural, di antaranya adalah minimnya verifikasi identitas pelapor, keterbukaan data pribadi kepada publik yang tidak berkepentingan, tidak adanya mekanisme pelacakan status barang yang transparan, serta kerentanan terhadap klaim palsu.

Digitalisasi layanan kampus melalui sistem informasi berbasis web menjadi solusi yang menjanjikan untuk mengatasi kelemahan tersebut. Namun, digitalisasi juga menghadirkan tantangan baru di bidang keamanan informasi. Sistem yang menyimpan data sensitif seperti identitas mahasiswa, informasi kontak, foto barang, dan riwayat laporan memerlukan perlindungan yang memadai agar tidak terjadi kebocoran data, manipulasi informasi, atau akses tidak sah oleh pihak yang tidak berwenang (OWASP Foundation 2021).

Framework Authentication, Authorization, dan Accounting (AAA) merupakan pendekatan terstruktur dalam keamanan sistem informasi yang telah terbukti efektif dalam berbagai implementasi sistem web. Autentikasi memastikan identitas pengguna yang mengakses sistem, otorisasi menentukan hak akses yang dimiliki pengguna sesuai perannya, sedangkan akuntansi mencatat seluruh aktivitas pengguna untuk keperluan audit dan pemantauan (Stallings 2017). Implementasi ketiga komponen ini secara terpadu dapat meningkatkan keamanan sistem secara komprehensif.

Penelitian terdahulu menunjukkan bahwa kelemahan autentikasi dan otorisasi merupakan salah satu dari sepuluh risiko keamanan aplikasi web teratas yang paling umum ditemukan (OWASP Foundation 2021). Studi yang dilakukan oleh Alwi dan Islam (2016) mengidentifikasi bahwa sistem manajemen informasi kampus rentan terhadap serangan injeksi dan pengambilalihan sesi pengguna. Lebih lanjut, penelitian oleh Ometov et al. (2018) menunjukkan bahwa implementasi autentikasi multi-lapis secara signifikan mengurangi kejadian akses tidak sah pada sistem berbasis web. Dalam konteks enkripsi data, penelitian McGrew dan Viega (2004) membuktikan bahwa mode AES-GCM menawarkan keamanan dan performa yang optimal untuk sistem yang memerlukan proteksi *data at rest* maupun *data in transit*.

Penelitian ini bertujuan mengimplementasikan *framework AAA* pada Sistem *Lost and Found IPB University* dan mengevaluasi dampaknya terhadap keamanan sistem serta performa respons. Rumusan masalah yang dijawab meliputi: (1) bagaimana merancang sistem yang aman dari ancaman *session hijacking* dan pencurian data; (2) mekanisme enkripsi apa yang paling sesuai untuk *data at rest*; (3) bagaimana merancang protokol manajemen kunci kriptografi; dan (4) bagaimana mengintegrasikan seluruh lapisan keamanan secara kohesif ke dalam alur logika sistem.

METODE

Gambaran Sistem

Sistem target adalah aplikasi web *Lost and Found IPB University* yang dirancang untuk memfasilitasi pelaporan dan pencarian barang hilang di lingkungan kampus. Sistem ini melibatkan dua kategori pengguna: (1) Mahasiswa, yang dapat melaporkan barang hilang atau temuan dan melacak status laporan; (2) Admin, yang mengelola tiket, memverifikasi laporan, dan memperbarui status barang; Fitur utama mencakup manajemen akun, pembuatan dan pengelolaan tiket laporan barang hilang/ditemukan, dan sistem notifikasi.

Analisis Ancaman (Threat Modeling)

Analisis ancaman dilakukan menggunakan metodologi STRIDE (*Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege*) untuk mengidentifikasi, menilai, dan memprioritaskan ancaman keamanan pada sistem (Shostack 2014). Identifikasi aset data sensitif dilakukan terlebih dahulu untuk menentukan komponen yang memerlukan perlindungan, meliputi data akun pengguna, data barang hilang, foto barang, riwayat tiket, dan informasi kontak pelapor. Berdasarkan hasil analisis STRIDE, dua ancaman utama yang diprioritaskan adalah *SQL Injection* (risiko sangat tinggi) dan *session hijacking* (risiko tinggi).

Implementasi Authentication (Autentikasi)

Komponen autentikasi dirancang dengan pendekatan berlapis. Password pengguna tidak pernah disimpan dalam bentuk teks biasa (plain text), melainkan di-hash menggunakan algoritma *bcrypt* dengan *salt* acak sebelum disimpan ke basis data. *Bcrypt* dipilih karena secara inheren lambat (*computationally expensive*) (Provos & Mazières 1999).

Mekanisme *session management* menggunakan token sesi unik yang diregenerasi setelah setiap login berhasil, dengan waktu kadaluarsa yang telah ditentukan.

Implementasi Authorization (Otorisasi)

Otorisasi diimplementasikan menggunakan model *Role-Based Access Control* (RBAC). Hak akses ditentukan berdasarkan peran pengguna dalam sistem. Tabel 1 menunjukkan distribusi hak akses untuk masing-masing peran.

Tabel 1 Distribusi hak akses berdasarkan peran pengguna

Peran	Hak Akses
User (Mahasiswa)	Membuat laporan, melihat laporan pribadi, klaim barang
Admin	Verifikasi laporan, perbarui status, kelola tiket

Validasi peran dilakukan di sisi server pada setiap permintaan yang memerlukan hak akses tertentu. Upaya akses ke sumber daya di luar peran pengguna secara otomatis ditolak dengan mengembalikan respons HTTP 403 Forbidden.

Implementasi Accounting (Akuntansi)

Komponen akuntansi mencatat seluruh aktivitas signifikan dalam sistem sebagai *audit trail*. Setiap entri log menyimpan informasi jenis aktivitas, stempel waktu, alamat IP, dan hasil operasi. Tabel 2 menunjukkan aktivitas-aktivitas yang dicatat dalam sistem log.

Tabel 2 Aktivitas yang dicatat dalam audit trail

Kategori	Aktivitas yang Dicatat
Autentikasi	Login berhasil
Pengelolaan Tiket	Pembuatan tiket, pembaruan status, verifikasi admin
Akses Data	Akses data sensitif, unduhan foto barang

Implementasi Enkripsi Data (AES-GCM)

Data sensitif pengguna dienkripsi menggunakan algoritma AES-GCM (*Advanced Encryption Standard - Galois/Counter Mode*) sebelum disimpan ke basis data. AES-GCM dipilih karena menyediakan *Authenticated Encryption with Associated Data* (AEAD), yang menggabungkan enkripsi data dan verifikasi integritas dalam satu mekanisme yang efisien

(Dworkin 2007). Mode ini merupakan standar modern yang digunakan pada protokol TLS/HTTPS dan direkomendasikan oleh NIST (2001). Tabel 3 membandingkan mode operasi AES yang dipertimbangkan.

Tabel 3 Perbandingan mode operasi AES

Mode	Confidentiality	Integrity Check	Authentication	Standar Modern
AES-GCM	Ada	Ada	Ada	Ya (TLS/HTTPS)
AES-CBC	Ada	Tidak	Perlu HMAC	Mulai ditinggalkan
AES-CTR	Ada	Tidak	Tidak ada	Jarang untuk web

Kunci enkripsi 256-bit disimpan secara terpisah dari basis data utama menggunakan layanan Key Vault/HSM (*Hardware Security Module*) untuk mencegah kebocoran kunci. Rotasi kunci dilakukan secara berkala sesuai kebijakan manajemen kunci organisasi (Ferguson et al. 2010).

Arsitektur Keamanan Sistem

Untuk memitigasi risiko keamanan siber utama yang telah diprioritaskan pada tahap *threat modeling*, sistem ini mengadopsi rancangan baru yang berfokus pada pemisahan kontrol yang ketat antara *Authentication*, *Authorization*, dan *Accounting* (AAA), serta perlindungan data menyeluruh baik pada saat transit maupun saat disimpan (*data at rest*). Berdasarkan visualisasi tata letak arsitektur, mekanisme keamanan dalam Sistem *Lost and Found* ini dibagi secara hierarkis ke dalam empat lapisan (*layer*) terisolasi yang saling berinteraksi sebagai berikut:

- **A. Client Layer (Browser & Client):** Berfungsi sebagai antarmuka awal pengguna (mahasiswa atau admin). Seluruh interaksi dari lapisan ini wajib disalurkan melalui protokol komunikasi aman HTTPS (TLS) untuk mengeliminasi risiko intersepsi data (*sniffing*) di jaringan publik.
- **B. Application Layer Backend:** Merupakan pusat pengendalian alur data dan logika keamanan sebelum menyentuh basis data. Lapisan ini memproses urutan validasi linear yang meliputi: verifikasi kredensial untuk menerbitkan *Session Token* (Autentikasi); pemeriksaan hak akses berdasarkan peran pengguna setelah menerima *Request* sesi (Otorisasi RBAC); penyaringan seluruh data masuk untuk memastikan data berstatus aman (Validasi & Sanitasi Input); pengubahan data sensitif menjadi *Ciphertext* terproteksi tinggi (Enkripsi AES-256-GCM); serta pengeksekusian instruksi akhir ke lapisan penyimpanan (*Database Operations*).
- **C. Security Isolated Layer (Key Vault/.env):** Merupakan lapisan isolasi mandiri yang bertugas mengelola siklus hidup *AES-256-GCM Key* secara terpisah dari server database utama. Mekanisme penanganan kunci bekerja secara dua arah melalui modul panggilan (*Minta kunci* untuk enkripsi dan *Kirim kunci* untuk AES) guna menjamin kunci tidak terekspos dalam bentuk *plain text* di layer aplikasi umum.

- D. *Database Layer (PostgreSQL)*: Lapisan penyimpanan akhir berbasis *PostgreSQL* yang diperketat melalui kebijakan eksekusi *query* menggunakan *Prepared Statement Only* demi mitigasi serangan injeksi secara absolut, serta pemisahan penyimpanan fisik antara blok Data Terenkripsi (*Ciphertext*) dan berkas *Audit Log - Append Only*

Keamanan Basis Data

Pencegahan *SQL Injection* diimplementasikan dengan menggunakan *Prepared Statement* atau ORM (*Object-Relational Mapping*) secara konsisten pada seluruh operasi basis data. Pendekatan ini memisahkan kode SQL dari data input pengguna sehingga karakter berbahaya tidak dapat diinterpretasikan sebagai perintah SQL (OWASP Foundation 2021). Selain itu, prinsip *least privilege* diterapkan pada akun basis data aplikasi, di mana akun tersebut hanya diberikan hak akses minimum yang diperlukan untuk menjalankan fungsinya.

Metode Pengujian

Pengujian sistem dilakukan dalam dua tahap utama. Pertama, pengujian keamanan fungsional menggunakan skenario uji terstruktur untuk memvalidasi setiap komponen AAA. Kedua, pengujian performa dilakukan dengan mengukur waktu respons sistem sebelum dan sesudah implementasi AAA menggunakan alat pengukuran berbasis Apache JMeter dengan 100 pengguna simultan. Overhead performa dihitung menggunakan rumus:

$$\text{Overhead (\%)} = ((T_{\text{AAA}} - T_{\text{dasar}}) / T_{\text{dasar}}) \times 100\%$$

di mana T_{AAA} adalah waktu respons dengan implementasi AAA dan T_{dasar} adalah waktu respons sistem tanpa AAA.

HASIL DAN PEMBAHASAN

Hasil Threat Modeling

Berdasarkan analisis STRIDE yang dilakukan, dua ancaman utama berhasil diidentifikasi serta tingkat resikonya. Tabel 4 menyajikan rangkuman hasil analisis risiko.

Tabel 4 Hasil analisis risiko berdasarkan threat modeling STRIDE

Ancaman	Komponen Terancam	Probabilitas	Dampak	Level Risiko	Prioritas
SQL Injection	Database Sistem	Sedang	Sangat Tinggi	Sangat Tinggi	1
Session Hijacking	Session Login	Sedang	Tinggi	Tinggi	2
XSS Injection	Form Input	Tinggi	Sedang	Sedang	3
Insider Threat	Data Sensitif	Rendah	Tinggi	Sedang	4

Hasil *threat modeling* menunjukkan bahwa *SQL Injection* merupakan ancaman dengan prioritas tertinggi karena berpotensi mengekspos seluruh basis data pengguna sekaligus, yang berimplikasi pada pelanggaran regulasi perlindungan data pribadi. *Session hijacking* diprioritaskan kedua karena tingginya dampak terhadap integritas akun pengguna individual.

Hasil Pengujian Authentication

Pengujian autentikasi dilakukan dengan enam skenario uji yang mencakup seluruh alur autentikasi. Tabel 5 menyajikan hasil pengujian autentikasi.

Tabel 5 Hasil pengujian komponen Authentication

Skenario Uji	Input	Hasil yang Diharapkan	Hasil Aktual
Login valid	Username & password benar	Login berhasil	LULUS
Password salah	Username benar, password salah	Login ditolak	LULUS
Username tidak terdaftar	Username tidak ada	Login ditolak	LULUS
Session expired	Token kadaluarsa	Logout otomatis	LULUS
Transmisi HTTP	Akses via non-HTTPS	Redirect ke HTTPS	LULUS
Password hashing	Cek database langsung	Password tersimpan sebagai hash	LULUS

Seluruh enam skenario pengujian autentikasi berhasil lulus dengan hasil sesuai ekspektasi. Verifikasi langsung pada basis data mengonfirmasi bahwa tidak ada password yang tersimpan dalam bentuk *plain text*; seluruh *password* tersimpan sebagai *hash bcrypt* dengan *salt* acak.

Hasil Pengujian Authorization

Pengujian otorisasi dilakukan untuk memvalidasi bahwa sistem RBAC berfungsi sesuai rancangan. Tabel 6 menyajikan hasil pengujian otorisasi.

Tabel 6 Hasil pengujian komponen Authorization

Skenario Uji	Peran Penguji	Tindakan	Hasil
Akses halaman admin	User (Mahasiswa)	Buka /admin/dashboard	DITOLAK (403)
Verifikasi laporan	Admin	Verifikasi tiket	DIIZINKAN
Akses laporan orang lain	User A	Lihat laporan User B	DITOLAK (403)
Modifikasi status tiket	User	Edit status via URL	DITOLAK (403)

Hasil pengujian menunjukkan bahwa sistem RBAC berfungsi dengan benar. Semua upaya akses lintas peran berhasil dicegah pada sisi server, termasuk upaya modifikasi status tiket secara langsung melalui manipulasi URL yang umum dilakukan oleh pengguna jahat.

Hasil Pengujian Accounting

Pengujian akuntansi memvalidasi kelengkapan dan keakuratan pencatatan *audit trail*. Tabel 7 menyajikan aktivitas-aktivitas yang diuji beserta status pencatatannya.

Tabel 7 Hasil pengujian komponen Accounting (Audit Trail)

Aktivitas	Informasi yang Diharapkan Tercatat	Tercatat
Login berhasil	ID pengguna, waktu, IP address	Ya
Pembuatan tiket	ID pengguna, ID tiket, waktu	Ya
Verifikasi tiket oleh admin	ID admin, ID tiket, status baru, waktu	Ya
Akses data sensitif	ID pengguna, jenis data diakses, waktu	Ya

Seluruh empat jenis aktivitas yang diuji berhasil tercatat dalam log sistem dengan informasi yang lengkap. *Audit trail* yang dihasilkan memenuhi persyaratan minimum untuk keperluan investigasi forensik digital dan pemantauan kepatuhan sistem.

Analisis Kinerja (Performance Analysis)

Pengukuran kinerja dilakukan untuk mengevaluasi dampak implementasi AAA terhadap performa sistem. Pengujian menggunakan Apache JMeter dengan 100 pengguna simultan dan 10 iterasi untuk setiap operasi. Tabel 8 menyajikan perbandingan waktu respons sebelum dan sesudah implementasi AAA.

Tabel 8 Perbandingan kinerja sistem sebelum dan sesudah implementasi AAA

Aktivitas	Sebelum AAA (ms)	Sesudah AAA (ms)	Overhead (%)
Login	120	145	20.83
Akses Dashboard	90	108	20.00
Pembuatan Tiket	150	182	21.33
Pengambilan Data Sensitif	95	115	21.05
Rata-rata	113.75	137.50	20.88

Hasil pengukuran menunjukkan bahwa implementasi AAA menambah overhead performa rata-rata sebesar 20,88%. Overhead ini terutama disebabkan oleh operasi *hashing bcrypt* pada autentikasi, verifikasi token sesi, pengecekan hak akses RBAC, dan operasi enkripsi/dekripsi AES-GCM. Meskipun demikian, nilai *overhead* ini masih dalam batas yang dapat diterima untuk aplikasi web; standar industri umumnya menerima *overhead* hingga 30% untuk implementasi keamanan (Stallings 2017).

Waktu respons absolut yang dicapai (rata-rata 137,50 ms) masih berada di bawah ambang batas 200 ms yang dianggap sebagai respons instan oleh pengguna menurut standar Nielsen (1993) dalam konteks interaksi manusia-komputer. Hal ini menunjukkan bahwa peningkatan keamanan yang signifikan berhasil dicapai tanpa mengorbankan pengalaman pengguna secara berarti.

Pembahasan Umum

Implementasi *framework* AAA pada Sistem *Lost and Found* IPB University berhasil mengatasi seluruh kelemahan yang diidentifikasi pada sistem informal yang ada sebelumnya. Privasi data pelapor dilindungi melalui enkripsi AES-GCM dan kontrol akses berbasis peran yang mencegah pengguna melihat data laporan milik orang lain.

Hasil ini sejalan dengan temuan penelitian terdahulu. Ometov et al. (2018) melaporkan bahwa implementasi autentikasi multi-lapis mengurangi kejadian akses tidak sah hingga 94% pada sistem berbasis web yang serupa. Penggunaan AES-GCM sebagai standar enkripsi *data at rest* sejalan dengan rekomendasi NIST SP 800-38D (Dworkin 2007) dan menjadi praktik terbaik dalam keamanan sistem web modern.

Limitasi utama penelitian ini adalah pengujian performa dilakukan dalam lingkungan terkontrol dengan data sintetis; pengujian pada beban nyata dengan data pengguna aktual dapat menghasilkan nilai *overhead* yang berbeda. Selain itu, implementasi *Key Vault/HSM* masih bersifat simulasi dan belum diuji pada infrastruktur produksi sesungguhnya.

SIMPULAN

Implementasi *framework Authentication, Authorization, dan Accounting* (AAA) berhasil diterapkan pada Sistem *Lost and Found* IPB University. Seluruh pengujian keamanan fungsional menunjukkan hasil sesuai kebutuhan: sistem autentikasi berbasis *bcrypt* berhasil menolak seluruh percobaan login tidak valid, mekanisme RBAC berhasil mencegah seluruh

upaya akses lintas peran, dan audit trail berhasil mencatat semua aktivitas kritis dengan informasi yang lengkap. Enkripsi AES-GCM yang diimplementasikan memberikan perlindungan ganda berupa kerahasiaan data dan verifikasi integritas dalam satu mekanisme yang efisien.

Pengukuran kinerja menunjukkan overhead performa rata-rata sebesar 20,88% akibat penambahan lapisan keamanan, namun masih dalam batas yang dapat diterima dengan waktu respons absolut di bawah 200 ms untuk seluruh operasi yang diuji. Hasil penelitian ini membuktikan bahwa implementasi keamanan berlapis yang komprehensif dapat dicapai tanpa mengurangi kenyamanan pengguna secara signifikan, sehingga sistem yang dihasilkan siap untuk diimplementasikan sebagai solusi pengelolaan barang hilang yang aman di lingkungan kampus IPB *University*.

DAFTAR PUSTAKA

- Alwi SHM, Islam AFMZ. 2016. Threats analysis for web application firewall. Di dalam: Proceeding of 6th International Conference on Information and Communication Technology for the Muslim World (ICT4M); 2016 Nov 22-24; Jakarta, Indonesia. hlm 170-175. DOI: 10.1109/ICT4M.2016.041
- Dworkin M. 2007. Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. NIST Special Publication 800-38D. Gaithersburg (US): National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-38D>
- Ferguson N, Schneier B, Kohno T. 2010. Cryptography Engineering: Design Principles and Practical Applications. Indianapolis (US): Wiley Publishing.
- Grassi PA, Garcia ME, Fenton JL. 2017. Digital Identity Guidelines: Authentication and Lifecycle Management. NIST Special Publication 800-63B. Gaithersburg (US): National Institute of Standards and Technology. Doi: <https://doi.org/10.6028/NIST.SP.800-63B-4>
- McGrew DA, Viega J. 2004. The security and performance of the Galois/counter mode of operation. Di dalam: Canteaut A, Viswanathan K, editor. Progress in Cryptology – INDOCRYPT 2004. Berlin (DE): Springer. hlm 343-355. https://doi.org/10.1007/978-3-540-30556-9_27
- [NIST] National Institute of Standards and Technology. 2001. Advanced Encryption Standard (AES). FIPS Publication 197. Gaithersburg (US): National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.FIPS.197>
- Ometov A, Bezzateev S, Mäkitalo N, Andreev S, Mikkonen T, Koucheryavy Y. 2018. Multi-factor authentication: a survey. Cryptography. 2(1): 1-31. <https://doi.org/10.3390/cryptography2010001>
- [OWASP Foundation]. 2021. OWASP Top 10 Web Application Security Risks [Internet]. [diunduh 2025 Jan 10]. <https://owasp.org/www-project-top-ten/>
- [OWASP Foundation]. 2023. Authentication Cheat Sheet. OWASP Cheat Sheet Series [Internet]. [diunduh 2025 Jan 10]. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- Provos N, Mazières D. 1999. A future-adaptable password scheme. Di dalam: Proceedings of the USENIX Annual Technical Conference; 1999 Jun 6-11; Monterey, California. hlm 81-91.
- Shostack A. 2014. Threat Modeling: Designing for Security. Indianapolis (US): Wiley.

- Stallings W. 2017. Cryptography and Network Security: Principles and Practice Ed ke-7. London (GB): Pearson Education.
- Toth T, Kruegel C. 2022. Accurate buffer overflow detection via abstract payload execution. Di dalam: Recent Advances in Intrusion Detection. Berlin (DE): Springer. hlm 274-291. https://doi.org/10.1007/3-540-36084-0_15